

DATA PROCESSING AGREEMENT

Tattooista platform — GDPR Article 28 processor terms

Version 1.0 · Last updated: 12 June 2026

This Data Processing Agreement (“DPA”) forms part of, and is subject to, the Terms and Conditions between the parties governing use of the Tattooista platform (the “Agreement” / “Principal Agreement”). It governs the Processing of Personal Data by the Processor on behalf of the Controller in connection with the Services. Where this DPA conflicts with the Principal Agreement on data protection matters, this DPA prevails.

1. Parties

Processor: Olena Christensen, Individual Entrepreneur (FOP), trading as Tattooista, ave. Voskresenskyi, build 24, housing A, fl. 14, Kyiv, 02125, Ukraine (“Processor”, “we”, “Tattooista”).

Controller: The tattoo studio that has entered into the Principal Agreement and accepted this DPA (the “Controller”, “Studio”, “you”), as identified by the Studio account details on record.

Each a “Party” and together the “Parties”.

2. Definitions

“GDPR” means Regulation (EU) 2016/679. “Personal Data”, “Processing”, “Data Subject”, “Controller”, “Processor”, “Supervisory Authority” and “Personal Data Breach” have the meanings given in the GDPR. “Sub-processor” means any third party engaged by the Processor to Process Personal Data on behalf of the Controller. “Standard Contractual Clauses” (“SCCs”) means the clauses approved by the European Commission for the transfer of Personal Data to third countries (Commission Implementing Decision (EU) 2021/914).

3. Roles and scope

The Parties acknowledge that, in respect of the Personal Data of the Studio's own clients and staff Processed through the platform, the Studio is the Controller and Tattooista is the Processor. Tattooista Processes such Personal Data only to provide the Services and only on the Controller's documented instructions, including those set out in this DPA and the Principal Agreement. The subject matter, duration, nature, purpose, types of Personal Data and categories of Data Subjects are set out in Annex 1.

Tattooista acts as an independent Controller in respect of data it Processes for its own purposes (e.g. account administration, billing via the Merchant of Record, security, and platform analytics); such Processing is governed by the Tattooista Privacy Policy, not this DPA.

4. Processor obligations

The Processor shall:

- (a) Process the Personal Data only on the Controller's documented instructions, including with regard to transfers, unless required to do otherwise by Union or Member State law (in which case it shall inform the Controller of that legal requirement before Processing, unless the law prohibits this on important grounds of public interest);
- (b) ensure that persons authorised to Process the Personal Data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality;
- (c) implement the technical and organisational measures set out in Annex 3 to ensure a level of security appropriate to the risk;
- (d) respect the conditions in Clauses 5 and 6 for engaging Sub-processors;

- (e) taking into account the nature of the Processing, assist the Controller by appropriate technical and organisational measures, insofar as possible, in fulfilling the Controller's obligation to respond to Data Subject requests under Chapter III GDPR;
- (f) assist the Controller in ensuring compliance with the obligations in Articles 32 to 36 GDPR (security, breach notification, data protection impact assessments and prior consultation), taking into account the nature of Processing and information available to the Processor;
- (g) at the choice of the Controller, delete or return all Personal Data after the end of the provision of Services, and delete existing copies unless storage is required by law (see Clause 9);
- (h) make available to the Controller all information necessary to demonstrate compliance with Article 28 GDPR and allow for and contribute to audits, including inspections, as set out in Clause 8;
- (i) immediately inform the Controller if, in its opinion, an instruction infringes the GDPR or other data protection provisions.

5. Sub-processors — general authorisation

The Controller grants the Processor general written authorisation to engage the Sub-processors listed in Annex 2. The Processor shall inform the Controller of any intended addition or replacement of Sub-processors, giving the Controller the opportunity to object on reasonable data-protection grounds within a reasonable period before the new Sub-processor begins Processing.

Where the Processor engages a Sub-processor, it shall do so by way of a contract imposing data-protection obligations no less protective than those in this DPA, in particular providing sufficient guarantees to implement appropriate technical and organisational measures. The Processor remains fully liable to the Controller for the performance of the Sub-processor's obligations.

6. International transfers

Personal Data is hosted in the European Union (database) and the United States (application/compute layer), as detailed in Annex 2. To the extent Processing involves a transfer of Personal Data to a country outside the EEA that is not subject to an adequacy decision, such transfer shall be governed by the Standard Contractual Clauses, which are incorporated into this DPA by reference and completed as set out in Annex 2. The relevant module is Controller-to-Processor (Module Two).

[REVIEW: the EEA → US transfer (Vercel) relies on the SCCs and/or the EU–US Data Privacy Framework if the recipient is certified. Confirm the mechanism with a lawyer before scaling. The Processor being established in Ukraine — a third country with an EU adequacy decision pending/partial — is the part most worth a lawyer's review.]

7. Personal Data Breach

The Processor shall notify the Controller without undue delay after becoming aware of a Personal Data Breach affecting the Controller's Personal Data, and shall provide the Controller with sufficient information to allow the Controller to meet any obligations to report or notify the Breach under the GDPR. Notification shall be made to the Studio's account-contact email and shall describe, to the extent known, the nature of the Breach, the categories and approximate number of Data Subjects and records concerned, the likely consequences, and the measures taken or proposed.

8. Audit

The Processor shall make available to the Controller information reasonably necessary to demonstrate compliance with this DPA and Article 28 GDPR, and shall allow for and contribute to

audits and inspections conducted by the Controller or an auditor mandated by the Controller, on reasonable prior notice and no more than once per year (save where required by a Supervisory Authority or following a Personal Data Breach). The Parties shall agree the scope, timing and duration of any inspection so as to minimise disruption to the Services and to protect the confidentiality and security of other customers' data.

9. Deletion and return of data

On termination of the Services, or earlier at the Controller's written request, the Processor shall, at the Controller's choice, delete or return all Personal Data Processed on behalf of the Controller, and delete existing copies, unless Union or Member State law requires continued storage. The platform provides per-Studio export and deletion functionality; account and Studio deletion cascades to all related records scoped to the Studio.

10. Liability and miscellaneous

Each Party's liability arising out of or related to this DPA is subject to the limitations and exclusions of liability set out in the Principal Agreement. This DPA is governed by the laws of Ukraine, and the dispute-resolution provisions of the Principal Agreement apply. If any provision is found unenforceable, the remainder continues in effect. This DPA, together with its Annexes and the Principal Agreement, constitutes the entire agreement between the Parties regarding the Processing of Personal Data.

Annex 1 — Details of Processing

Subject matter: Provision of the Tattooista software-as-a-service platform (branded studio website, portfolio/gallery management, client records, booking management, reviews, and content pages).

Duration: For the term of the Principal Agreement, until deletion or return of Personal Data under Clause 9.

Nature and purpose: Hosting, storage, organisation, retrieval, display and deletion of Personal Data so the Studio can operate its public site and manage its clients and bookings.

Controller: The Studio. **Processor:** Tattooista.

Categories of Data Subjects

- The Studio's clients and prospective clients (people who book, are recorded as clients, or submit reviews/enquiries).
- The Studio's own personnel with platform accounts (owner and staff members).

Types of Personal Data

As Processed through the platform's data model:

- Client records: full name, optional avatar image, contact entries (type and value — e.g. phone, email, Instagram or other handle), and client gallery images (tattoo/work photographs uploaded against the client).
- Booking records: full name, optional email, optional phone, optional Instagram handle, free-text message/enquiry, and booking status.
- Reviews: rating, review text, and review gallery images, linked to a reviewing user.
- Studio personnel accounts: name, display name, email address, hashed password / authentication identifiers, and role (owner or staff).

[CONFIRM: add any other client-facing fields you collect, e.g. intake/consent form data, date of birth, or aftercare notes, if/when those features ship. None are present in the current schema.]

Special category data

The platform is not designed to collect special categories of Personal Data (Article 9 GDPR). The Studio must not upload special-category data except where it has a lawful basis and has informed Tattooista. Tattoo imagery may, depending on content, reveal information capable of being sensitive; the Studio is responsible for obtaining any necessary consents from its clients before uploading images or other client data.

Annex 2 — Authorised Sub-processors

The Controller authorises the following Sub-processors. Locations indicate where Personal Data is hosted or Processed.

Sub-processor	Purpose	Location
Vercel Inc.	Application hosting / compute layer (serving the platform)	United States
Neon (Postgres database)	Primary database — all structured Personal Data	European Union (Germany / Frankfurt)
Vercel Blob	Object storage for uploaded images (galleries, avatars, review media)	United States (US East)
Zoho Corporation (Zoho Mail)	Transactional and contact email delivery (SMTP)	European Union
Google LLC	Analytics and advertising (Google Analytics; Google AdSense / ad serving on free-tier studio sites)	United States
Paddle.com	Merchant of Record / billing (Studio billing data; not Studio-client data)	United Kingdom / EU

[NOTE: Paddle Processes Studio billing/account data as its own Controller / Merchant of Record, and Studio-client Personal Data does not flow to Paddle. Listed here for completeness/transparentcy.]

Transfer mechanism

For Sub-processors located outside the EEA without an adequacy decision (notably Vercel and Google in the United States), transfers are made under the Standard Contractual Clauses (Module Two, Controller-to-Processor) and/or, where the recipient is certified, the EU–US Data Privacy Framework. Supplementary measures (encryption in transit and at rest, access controls) apply as set out in Annex 3.

Annex 3 — Technical and Organisational Measures

The Processor implements and maintains the following measures (Article 32 GDPR):

- Encryption of Personal Data in transit (TLS/HTTPS) and at rest at the database and object-storage layers.
- Multi-tenant data isolation: all Studio data is scoped by a tenant identifier (studioid), with queries enforced through tenant-aware data-access helpers, so one Studio cannot access another Studio's data.
- Access control: authenticated accounts with role-based permissions (platform admin; Studio owner; Studio staff); passwords stored only as salted hashes; session management with secure tokens.
- Per-tenant data export and deletion; Studio deletion cascades to all related records.
- Regular routine backups of the database (the Controller remains responsible for its own records of activity).
- Use of reputable infrastructure providers (see Annex 2) that maintain their own recognised security certifications and controls.
- Logging and, where configured, error monitoring to detect and respond to incidents.

[CONFIRM / EXPAND once shipped: error monitoring (e.g. Sentry), documented backup cadence and retention, and any penetration-testing or incident-response process. Keep this annex aligned with what is actually in place.]

Acceptance

This DPA is accepted by the Studio (Controller) either by electronic acceptance during onboarding (recording the acceptance timestamp and DPA version against the Studio account) or by signature below. Acceptance binds the Studio to the terms above.

Processor	Controller (Studio)
Olena Christensen, Individual Entrepreneur (FOP), trading as Tattooista	[Studio legal name]
Signature: _____	Signature: _____
Name: Olena Christensen	Name: _____
Date: _____	Date: _____